Architecture blueprint: build an education-first ecosystem with its own domain, OIDC identity provider, and integrated app suite like Google and Microsoft

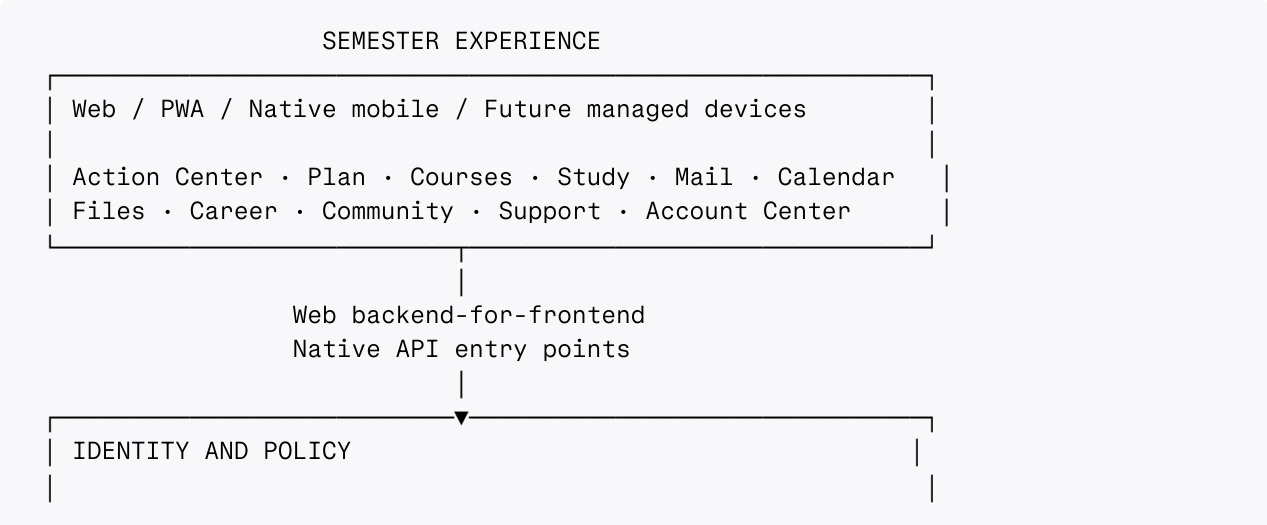
Computer
Strategic roadmap: how Semester can scale into an Apple-style closed-loop educational ecosystem with hardware, OS, and proprietary domain services
Computer
How would user sign-in and SSO work with Semester Accounts
Show me a technical architecture for Semester Mail
How does Semester handle multiple school connections

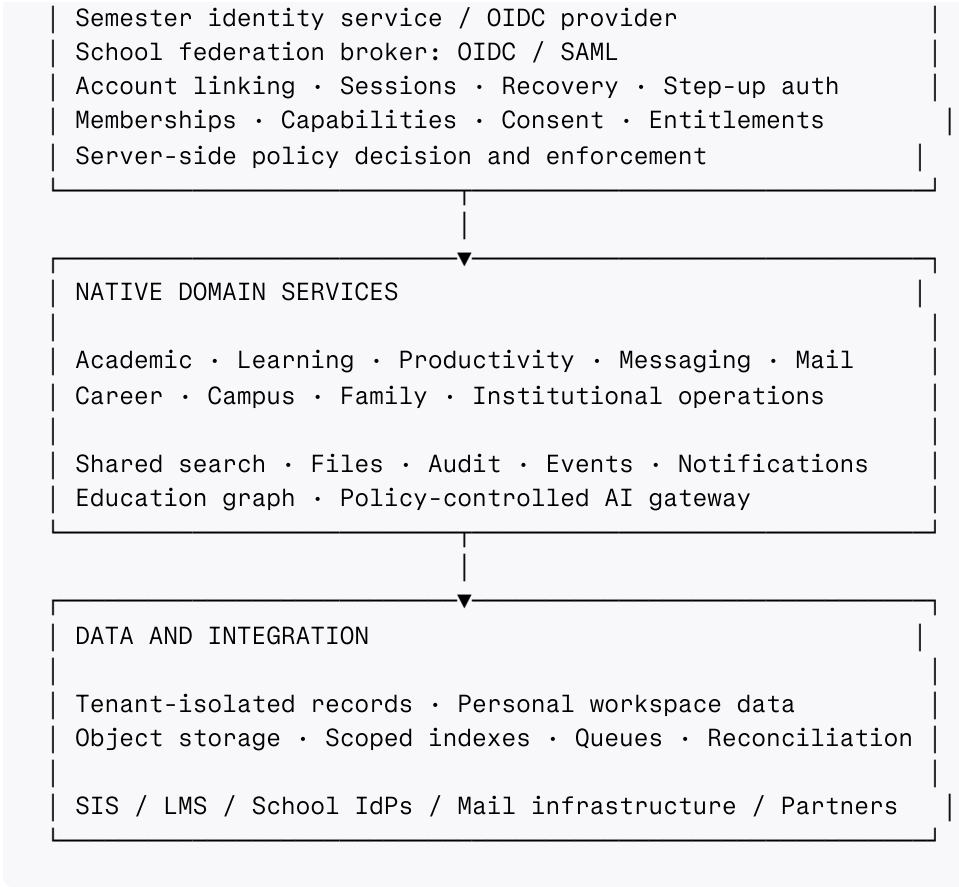
Semester should build a first-party account and services ecosystem around one persistent personal identity, with institution-specific access layered on top. That means its own domain, Semester Accounts, an OIDC identity service, Semester Mail, and an integrated app suite—all sharing the same security, permissions, workspace, and education graph.

For an Apple-style experience, the goal should be **coherence**, not lock-in: Semester controls the end-to-end experience while preserving standards-based interoperability, institutional authority, and user portability.

Below is a proposed technical architecture covering sign-in and SSO, mail, multiple school connections, and the longer-term device/OS roadmap. These are design specifications, not verified deployed capabilities.

1. Overall architecture





Start with clear module boundaries rather than immediately splitting every box into a microservice. Semester's supplied architecture already describes a modular-monolith direction and shared platform modules; this blueprint should reconcile with that work instead of creating another backend.[1]

Domain arrangement

Illustrative namespaces:

```
<semester-domain>                 Company and product website
app.<semester-domain>             Unified application
account.<semester-domain>         Account and security center
identity.<semester-domain>        OIDC issuer
mail.<semester-domain>            Mail interface
developers.<semester-domain>      Developer documentation
status.<semester-domain>          Service status
```

The actual registered domain and issuer must be verified before implementation. Once published, treat the OIDC issuer as durable infrastructure—not something renamed casually during a branding change.

2. How Semester sign-in and SSO should work

Semester needs two related identity roles:

1. Identity provider: authenticates people to Semester applications and, later, approved partner applications.
2. Federation broker: accepts authentication from an institution's identity provider and maps it to a Semester identity and authorized institutional membership.

OpenID Connect provides the standard authentication layer for exchanging identity assertions between an identity provider and relying applications.[2]

A. Personal Semester Account sign-in

Recommended web flow:

```
User opens Semester
       ↓
App redirects to Semester identity service
       ↓
User authenticates with a passkey or supported method
       ↓
Identity service returns a one-time authorization code
       ↓
App backend exchanges code using PKCE
       ↓
Backend validates identity response
       ↓
App creates a secure server-side session
       ↓
Policy service resolves permitted workspaces
```

Use Authorization Code flow with PKCE, including the `S256` challenge method. PKCE protects the authorization-code exchange against interception; it is not a replacement for session protection or authorization.[3] [4]

For the web application, use a backend-for-frontend that holds tokens server-side and gives the browser a `Secure`, `HttpOnly` session cookie with appropriate SameSite and CSRF controls. Do not put long-lived tokens in browser local storage.

For native apps, use the system browser, PKCE, and operating-system secure storage rather than an embedded credential-collection screen.

B. Institution SSO

```
User chooses “Continue with my school”
       ↓
Semester identifies the approved institution connection
       ↓
Redirect to institution IdP
       ↓
```

```
Institution authenticates the user
       ↓
Semester validates the federation response
       ↓
Resolve external identity mapping
       ↓
Resolve verified membership and current roles
       ↓
Create session with appropriate authentication assurance
```

Authentication proves who signed in. It does not, by itself, establish every permission that person should receive.

School access must also resolve:

```
Active account
+ active membership
+ capability
+ organizational/resource scope
+ institutional policy
+ consent where required
+ workflow state
= allowed / denied / step-up / approval required
```

This follows Semester's existing requirement for one canonical account, membership, capability, consent, and policy system. [5]

C. Account linking

Suppose someone already has a personal Semester Account and later signs in through a university.

The safe linking workflow is:

1. Authenticate the existing Semester Account.
2. Authenticate the school identity.
3. Confirm the specific identities being connected.
4. Check for conflicting existing mappings.
5. Add the verified external-identity relationship.
6. Record the security event and notify the user.
7. Resolve institution membership separately.

Never automatically merge accounts because both identities contain the same email address. Use the provider's stable subject identifier; Google specifically identifies `sub`, not email, as the stable identity key. [6]

D. Token boundaries

Artifact	Purpose	What it must not become
ID token	Tells the client who authenticated	General authorization for every API
Access token	Permits access to a specific API audience and scope	Universal access to all Semester services
Refresh token	Renews access under controlled conditions	Permanent, unrestricted credential
App session	Maintains the authenticated application experience	Proof that institutional roles are still active

OIDC validation must include signature verification and issuer, audience, and expiration checks, with nonce validation where applicable. Issuer and audience matching are explicit protocol requirements. [7]

Keep mutable school permissions out of long-lived tokens. Resolve consequential permissions against current server-side state.

E. SSO across Semester's app suite

Mail, Calendar, Files, and Learning should redirect through the same identity service. Its existing session can avoid another login prompt, while each app receives its own appropriately scoped session or tokens.

Do not implement SSO by sharing one broadly scoped cookie across every subdomain.

For school-sensitive actions, require the institution's approved authentication assurance. Signing into a personal account should not bypass an institution's requirement for school SSO or stronger authentication.

3. Multiple schools: one person, separate authorities

The central model is:

```
Person
  └── Semester Account
       ├── Personal workspace
       ├── Institution A membership
       │    ├── Student role
       │    └── Institution-governed resources
       ├── Institution B membership
       │    ├── Applicant role
       │    └── Institution-governed resources
       └── Institution C membership
            ├── Alumni role
            └── Institution-governed resources
```

One login can expose multiple workspaces. It must not combine their authorization boundaries.

Proposed canonical relationships

These are logical entities to reconcile with existing tables—not instructions to create duplicates.

Entity	Important fields and constraints
Account	Immutable account ID, status, recovery configuration
External identity	Provider/connection, issuer, subject, linked account
Institution membership	Account, tenant, lifecycle state, verification source
Role assignment	Membership, capability set, scope, effective dates
Workspace	Personal or institution-governed ownership
Resource relationship	Course enrollment, advisor assignment, organization membership
Consent grant	Grantor, recipient, purpose, resource scope, expiry
Service entitlement	Account or tenant, service, quota, lifecycle

An external identity mapping should be unique within its authoritative connection and issuer/subject namespace. An email string is an attribute, not the uniqueness foundation.

Workspace switching

The interface could show:

```
Personal
Institution A — Student
Institution B — Applicant
Institution C — Alumni
```

The browser may request a workspace switch, but the server must verify membership. A client-provided tenant ID is never authority.

Search, files, notifications, exports, and AI retrieval must enforce the same boundary. A unified search screen may show separate permitted result groups without blending confidential institutional content.

Cross-school planning

Semester can offer a personal view of:

- Schedules from multiple permitted sources.
- Application deadlines.
- User-controlled academic plans.
- Career and portfolio evidence.
- Potential transfer-credit questions.

But it should not declare a course officially transferable or satisfy another school's degree requirements without the receiving institution's authoritative decision. Personal planning and official academic determination remain separate.

Offboarding

When Institution A ends access:

- Revoke Institution A permissions and relevant sessions.
- Preserve unrelated memberships.
- Preserve eligible personal data.
- Apply Institution A retention and export policies.
- Remove Institution A content from search and AI access where authorization expires.

Semester's existing lifecycle specification already requires institution-specific offboarding, retention checks, credential revocation, and portability.[5]

4. Technical architecture for Semester Mail

Semester Mail needs both an application layer and actual mail infrastructure.

```
INBOUND
Internet sender
      ↓
DNS MX → Mail ingress
      ↓
Recipient validation + authentication evaluation
      ↓
Spam / phishing / malware controls
      ↓
Durable delivery queue
      ↓
Mailbox store + attachment store
      ↓
Scoped search index + change events
      ↓
Semester Mail interface

OUTBOUND
Semester composer
      ↓
Mail API / submission service
      ↓
Account + mailbox + sender authorization
      ↓
Quota / abuse / attachment checks
      ↓
Durable submission queue
      ↓
DKIM signing + SMTP delivery infrastructure
      ↓
Recipient provider
```

```
      ↓
Delivery status / bounce handling
```

A. Control plane versus data plane

Control plane	Data plane
Address reservation and provisioning	Message reception and delivery
Mailbox ownership and entitlements	Message bodies and attachments
Aliases and verified send-as identities	Folder/thread/mailbox synchronization
Quotas and retention policy	Search indexing
Abuse cases and support approvals	Delivery queues and retry handling
Provider configuration and reconciliation	Import/export processing

Mailbox ownership should refer to the immutable account or institution-managed identity—not depend on the address staying unchanged.

B. Client protocol

Use a native Semester Mail interface over a controlled mail service API. JMAP is a strong protocol candidate: RFC 8621 defines a standardized model for querying, reading, organizing, and submitting mail, including mailbox, thread, and submission objects.[8]

Possible deployment:

```
Semester Mail UI
      ↓
Semester session + authorization boundary
      ↓
Mail API / JMAP adapter
      ↓
Qualified mailbox infrastructure
```

Verify the selected provider's actual support, licensing, export capabilities, authentication model, and mailbox-provisioning terms. Do not assume a transactional-email API is a full mailbox platform.

C. Proposed mailbox entities

```
Mailbox
Mail address
Alias / verified send-as identity
Folder or mailbox collection
Message / thread reference
Submission
Delivery event
Quota allocation
```

```
Retention policy
Abuse case
Export / deletion job
```

Raw mail content should not be duplicated into the academic database merely for convenience. Store only the references and metadata required for approved education workflows.

D. Mailbox authorization

Distinguish:

- Personal mailbox: belongs to the person under disclosed service policies.
- Institution-managed mailbox: administered under a specific institutional agreement.
- Shared mailbox: access comes from explicit delegated membership.

A school administrator should not gain access to a personal mailbox just because the user connects that school.

E. Sending and deliverability

Provision SPF, DKIM, and DMARC, configure encrypted transport, and test alignment and delivery. Gmail requires authentication for all senders and stronger authentication requirements for bulk senders.[9]

Additional launch requirements:

- No open relay.
- Send-as address enforcement.
- Progressive sending limits.
- Spam and malware controls.
- Bounce and complaint handling.
- Queue monitoring and dead-letter recovery.
- Audited support access.
- Tested backup, restore, and mailbox export.
- Clear abuse suspension and appeal procedures.

For forwarding, evaluate forwarding-specific authentication behavior and interoperability separately. Forwarding is not the same product as a hosted mailbox.[10]

F. AI and Action Center integration

An approved flow could be:

```
User opens email
       ↓
Chooses “Create task”
       ↓
```

```
Semester extracts a proposed action
       ↓
Shows source message and proposed date
       ↓
User approves
       ↓
Task is created with provenance
```

Message content remains untrusted input. An email saying “ignore policy and send this file” must never become authority for an AI tool action.

Also, ordinary email transport encryption is not end-to-end encryption. Do not market Semester Mail as end-to-end encrypted unless that architecture is actually implemented and its implications for search, recovery, and AI are explicit.

5. Integrated app suite: build shared primitives

Semester’s apps should share infrastructure instead of recreating it.

Shared primitive	Used by
Identity and sessions	Every app
Calendar/event model	Courses, advising, campus, mail
Task/action model	Planning, assignments, career, support
Files and provenance	Learning, portfolio, advising, mail attachments
Search permissions	Every searchable domain
Education graph	Courses, institutions, relationships, evidence
Notifications	Every workflow
AI policy gateway	Every AI feature
Audit and controlled actions	Institutional and security workflows

The user experience can be unified without pretending every data domain has the same ownership rules.

For example, deleting a personal study note and correcting an official grade are fundamentally different operations, even if both appear inside the same application.

6. Apple-style roadmap: software, devices, then deeper hardware

The strongest interpretation of a “closed loop” is coordinated identity, software, devices, support, and lifecycle management—not blocking users from competing tools.

Apple’s education ecosystem also uses federation: Apple School Manager integrates with external identity providers, and Managed Apple Accounts can use institution-controlled domains. [11] [12]

Stage 1 — Software ecosystem

Deliver:

- Semester Accounts.
- Institutional federation.
- Unified app suite.
- Account recovery and portability.
- Native mobile/PWA continuity.
- Semester Mail pilot.
- Shared policy and device-session controls.

Gate: core workflows, security, support, and cross-school boundaries have production evidence.

Stage 2 — Semester-managed device experience

Build a “Semester Workspace” experience on existing operating systems:

- Institution-approved app provisioning.
- Shared-device sign-out behavior.
- Offline learning and synchronization.
- Device/session revocation.
- Accessibility configuration.
- Managed versus personal data separation.

Institutional device management must not become permission to surveil a student’s personal device. Semester-level session revocation and full-device wipe are different powers.

Gate: approved device-management integrations, ownership policy, support, and tested loss/offboarding scenarios.

Stage 3 — Branded reference hardware

Evaluate partner-built devices before custom manufacturing:

- Semester-branded study tablet or laptop.
- Tested compatibility and accessibility.
- Repair and replacement process.
- Secure update lifecycle.
- Regional fulfillment and warranty support.
- Clear institutional procurement model.

Gate: demonstrated user need and viable lifecycle economics—not branding enthusiasm alone.

Stage 4 — Deeper OS integration

“Semester OS” can initially mean the education operating environment spanning applications and devices.

A literal operating-system distribution is a separate commitment requiring secure boot, drivers, updates, accessibility, application compatibility, recovery, and long-term maintenance. Pursue that only when existing operating systems demonstrably block important education workflows.

7. Build sequence, blockers, and evidence

Workstream	Owner	Required evidence before activation
Canonical identity reconciliation	Platform/identity lead	Existing schema, account mappings, linking and recovery tests
Domain and issuer setup	Security/platform lead	Ownership, DNS access, recovery, signing-key operations
Federation	Identity + institution IT	Approved connections, validation, provisioning/offboarding tests
Multi-school authorization	Platform/security lead	Cross-tenant negative tests across API, DB, files, search, AI
Semester Mail	Messaging/operations lead	Delivery, abuse, backup, export, provider exit evidence
App-suite integration	Domain leads	Shared primitive adoption and end-to-end workflow tests
Device experience	Device/product lead	Management consent, offline, loss, sign-out, support tests
Hardware expansion	Hardware/operations lead	Procurement, repair, update, support, and economic validation

The supplied architecture document records unresolved security/tenancy concerns and a phase marked “NO-GO · in progress.” It is dated evidence rather than a live deployment audit, but those blockers must be reconciled before enabling a new identity provider or publicly provisioned mailboxes.[1]

Maintain separate readiness labels for designed, implemented, tested, deployed, institution-authorized, and production-enabled capabilities.

The immediate technical priority is the identity and multi-school authorization spine. Once that is proven, Semester Mail and the integrated app suite can expand on the same foundation; devices and hardware then become extensions of a working ecosystem rather than substitutes for one.

⁂

1. The Main Semester design system (2) copy/uploads/Semester build Architecture.pdf
2. https://openid.net/developers/how-connect-works/
3. https://docs.redhat.com/en/documentation/red_hat_build_of_quarkus/3.20/html/openid_connect_oidc_authentication/security-oidc-code-flow-authentication

4. https://www.oidc.se/specifications/swedish-oidc-profile-1_0.html
5. The Main Semester design system (2) copy/handoff/specifications/role-system-execution-prompt.pdf
6. https://developers.google.com/identity/openid-connect/openid-connect
7. https://www.itu.int/rec/dologin_pub.asp?lang=e&id=T-REC-X.1285-202505-I!!PDF-E&type=items
8. https://www.rfc-editor.org/info/rfc8621/
9. https://support.google.com/mail/answer/81126?hl=en
10. https://developers.cloudflare.com/dns/manage-dns-records/how-to/email-records/
11. https://support.apple.com/guide/deployment/deploy-devices-apple-school-manager-business-depd3a5dd518/web
12. https://support.apple.com/guide/deployment/about-managed-apple-accounts-depdc4ba8d82/web
13. https://datatracker.ietf.org/doc/draft-ietf-jmap-mail/16/
14. https://support.apple.com/guide/deployment-education/decide-provide-access-apple-services-eduf11251f1f/web
15. https://openid.net/specs/openid-connect-core-1_0-14.html
16. https://www.iana.org/assignments/jmap
17. https://it-training.apple.com/deployment/tutorials/course/
18. https://stalw.art/docs/development/rfcs/
19. https://jmap.io/
20. https://www.systoolsgroup.com/updates/what-is-jmap/
21. https://openid.net/specs/openid-connect-core-1_0.html